Discovery Report: Designing a Secure Network for Onward Logistics Order System

Lab	Designing a Secure Network for Onward Logistics Order System
Name	Jordan Nguepi
Date	2026-10-26
Client	Onward Logistics (see the Client Profile)

1. What you found

The client's need

Onward Logistics needs its order system to stay available to merchants and customers through failures and sales-day peaks, while keeping internal order processing hidden from the internet and still easy and safe for engineers to maintain, at a cost Finance understands.

Solutions that exist

Solution	How it works	Trade off for this client
Single server with a public IP (today's setup)	One EC2 instance in one Availability Zone runs both the website and order processing, with SSH open for admins.	**Strength:** cheapest and simplest. **Weakness:** one failure takes everything offline, and internal services and admin ports are exposed to the internet.
Public + private subnets in one Availability Zone, with a bastion host	Web servers sit in a public subnet, internal servers in a private subnet, and engineers SSH through a bastion host.	**Strength:** internal servers are hidden from the internet. **Weakness:** losing that one zone is still a full outage, and the bastion keeps an open SSH port and shared keys, which the Head of Security has ruled out.
Multi-AZ tiered network with a load balancer, NAT Gateways and Session Manager	A load balancer spreads traffic across servers in two Availability Zones, all servers sit in private subnets, NAT Gateways give outbound-only internet, and engineers connect through AWS Systems Manager.	**Strength:** survives the loss of a whole zone, nothing internal is reachable, and there are no admin ports or keys. **Weakness:** higher running cost (about $150/month), mostly for the NAT Gateways and load balancer, which bill by the hour.

What happens with no solution

- **Lost revenue and trust on peak days.** With everything on one server in one zone, any hardware fault, data-centre problem or bad change stops all orders. Sales days triple volume, so an outage then costs the most, and merchants may move to a competitor they see as more reliable.
- **Real example:** on 7 December 2021, a disruption in AWS's us-east-1 region took down or degraded services for many companies for several hours. Infrastructure does fail, so AWS's Well-Architected Reliability Pillar advises spreading workloads across multiple Availability Zones so a single failure cannot take an application offline.
- **Breach and legal exposure.** Internal order services and SSH reachable from the internet are constantly scanned and brute-forced. Shared keys mean nobody can tell who accessed a server, and a leaked key can't be revoked for one person. A breach of order data could bring customer-notification duties under data-protection law (for example GDPR in the EU) and lasting reputational damage.
- **Slow recovery.** A hand-built server can't be rebuilt reliably, so recovery depends on someone remembering how it was set up.

Sources

- AWS Well-Architected Framework, Reliability Pillar: https://docs.aws.amazon.com/wellarchitected/latest/reliability-pillar/welcome.html
- Summary of the AWS Service Event in the Northern Virginia (US-EAST-1) Region, December 2021: https://aws.amazon.com/message/12721/
- Amazon VPC User Guide, NAT gateways: https://docs.aws.amazon.com/vpc/latest/userguide/vpc-nat-gateway.html
- Elastic Load Balancing, What is an Application Load Balancer?: https://docs.aws.amazon.com/elasticloadbalancing/latest/application/introduction.html

- AWS Systems Manager Session Manager: https://docs.aws.amazon.com/systems-manager/latest/userguide/session-manager.html
- AWS CloudFormation Git sync: https://docs.aws.amazon.com/AWSCloudFormation/latest/UserGuide/git-sync.html
- Amazon VPC pricing (NAT Gateway, public IPv4): https://aws.amazon.com/vpc/pricing/
- Elastic Load Balancing pricing: https://aws.amazon.com/elasticloadbalancing/pricing/

2. The business value of your solution

Your chosen approach

I chose the **multi-AZ tiered network** (Solution 3). It is the only option that meets all four leaders' needs at once. The website runs in two separate data centres (Availability Zones) in Frankfurt, behind one load balancer, so losing one zone does not stop orders. Only the load balancer faces the internet; the website servers and order services sit in private subnets that the internet cannot reach. Each zone has its own NAT Gateway so servers can still download updates, and engineers log in through Session Manager instead of SSH, with no open ports and no shared keys. Everything is defined in CloudFormation and deployed from Git, so it can be rebuilt at any time.

It costs about **$150/month** in Frankfurt, roughly half of it for the two NAT Gateways. A single NAT Gateway would save about $42/month, but if its zone failed, servers in the other zone would lose updates and admin access. I chose resilience over that saving because the system must keep working through a zone failure.

Services you will use

Service	The job it does	Why this service, used this way
Amazon VPC (6 subnets across 2 Availability Zones)	Private network split into public, private web and private app subnets in each zone.	Separates what must face the internet from what must not, with a copy of each tier in each zone so one zone failure can't take a tier down.
Application Load Balancer	The single public entry point; spreads customer traffic across the website servers in both zones.	Health checks stop traffic going to a failed server or zone automatically, and the servers behind it can stay private.
Amazon EC2 + Auto Scaling	Runs the website (2+ servers) and the order services (2 servers) on Free Tier Amazon Linux.	Auto Scaling replaces failed website servers and adds more on sales days, keeping one in each zone.
NAT Gateway (one per zone)	Lets private servers download updates without being reachable from the internet.	Outbound-only by design and managed by AWS. One per zone so updates and admin access keep working if a zone fails.
S3 Gateway Endpoint	Private route to Amazon S3, where Amazon Linux package repositories are hosted.	Free, and it keeps most update traffic off the NAT Gateway, lowering per-GB charges.
Security groups	Firewall rules: internet → load balancer → website servers → order services only.	Each tier accepts traffic only from the tier in front of it; no rule allows SSH (port 22).
AWS Systems Manager Session Manager + IAM	Gives engineers a shell on any server, using an IAM role with an AWS managed policy.	No open ports and no keys to share; access is granted and removed per person in IAM.
AWS CloudFormation with Git sync	Builds the whole environment from a template stored in GitHub.	Nothing is built by hand, every change is reviewed in Git, and the environment can be rebuilt from the repository.

Who benefits, and how you will know

Stakeholder	Benefit	How you would know
Chief Technology Officer	Merchants and customers can reach the website even if one data centre (zone) fails.	Terminate a website server or simulate a zone loss: the website URL keeps responding and Auto Scaling restores 2 healthy servers within minutes.
Head of Security	Nothing internal is reachable from the internet, and there are no admin ports or shared keys.	Internal servers have no public IP; no security group allows port 22; a connection attempt from the internet to an internal server fails.
Head of Operations	Engineers can still log in to every server, and servers can still install updates.	A Session Manager session opens on each internal server, and `sudo dnf install` succeeds from inside it.

Stakeholder	Benefit	How you would know
Finance Lead	A clear, itemised monthly cost with each expensive choice explained.	AWS Cost Explorer, filtered by the project's cost-allocation tags, matches the estimate of about $150/month.
Merchants and customers	The order site stays up, including on peak sales days.	Load balancer metrics show healthy targets and few 5xx errors during traffic peaks.

Limits and risks of your design

- **Single region.** If all of Frankfurt failed, the system would go down. Multi-region failover would cost much more and is out of scope.
- **Order services are not auto-healing.** They are two standalone servers with no load balancer between them, so if one fails it must be replaced by hand. A production design would put them in their own Auto Scaling Group behind an internal load balancer.
- **HTTP only.** The website uses HTTP; HTTPS needs a domain and a certificate (AWS Certificate Manager), which this lab doesn't include.
- **No data layer or backups.** Orders are not yet stored in a database, so data durability and backup are not addressed.
- **Cost can grow with traffic.** NAT Gateway and load balancer charges rise with data volume. Budgets and cost alerts should be set up.
- **No web application firewall.** The load balancer is open to the internet without AWS WAF, so application-level attacks are not filtered.